WebAssure

Know your website before you trust it.

Project write-up for HackMatrix 2026, AI-Powered Web Threat Detection and Digital Trust Intelligence

Team Fantastic 4: Souradeep Pradhan, Madhushree Dasgupta, Aniruddha Das and Sattwik Das

1. Overview

WebAssure helps people decide whether to trust a link, email, message or certificate before they act on it. Instead of a bare **safe** or **malicious** label, every report shows which checks ran, what each one found, the evidence behind it, what could not be checked and what to do next.

The system combines three layers. **Cybersecurity** checks collect technical evidence and produce a deterministic risk classification. **AI** explains that evidence in plain language and analyses scam messages, without being able to change a verdict. **Web3** records a salted fingerprint of a report on Ethereum Sepolia so anyone holding the receipt can independently verify that it has not been altered.

2. The problem

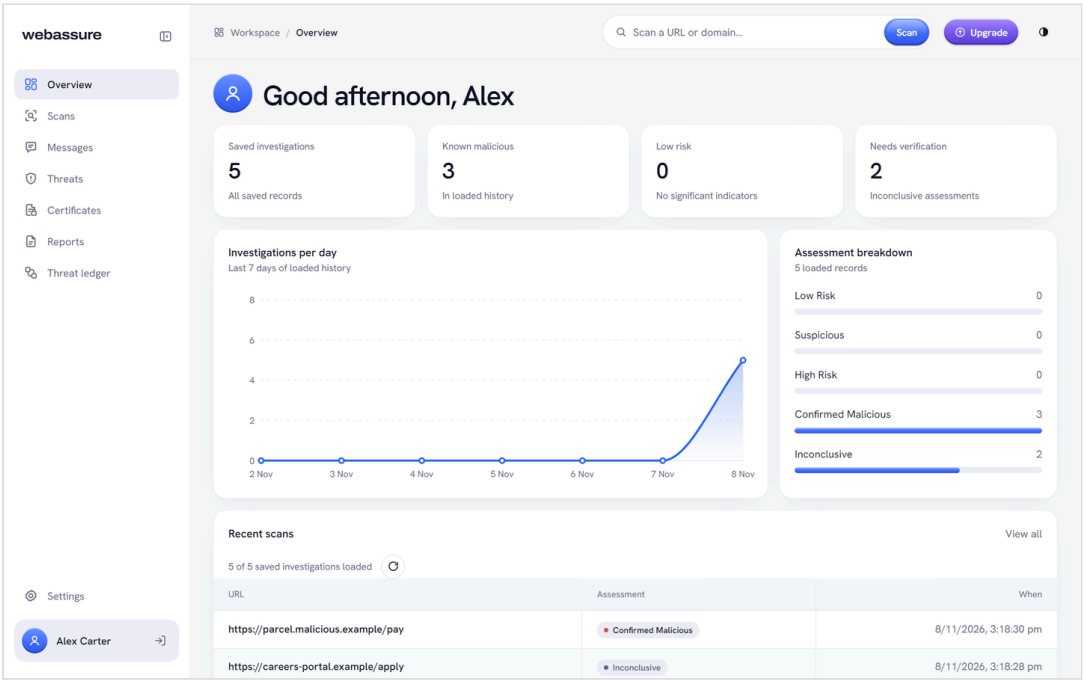
Phishing pages, fake job portals, fraudulent payment links and impersonated brands are increasingly hard to tell apart from the real thing. India recorded about Rs 19,813 crore in reported cyber fraud losses in 2025 across roughly 21.78 lakh complaints (I4C data). The Anti-Phishing Working Group counted 971,181 phishing attacks worldwide in the first quarter of 2026.

The trust infrastructure is exposed too. In October 2026, eMudhra disclosed that weak key generation affected eight intermediate certificates, and browser vendors moved to block them. A padlock shows an encrypted connection; it does not prove that a website is honest. People need an explanation they can check, not another opaque score.

3. What we built

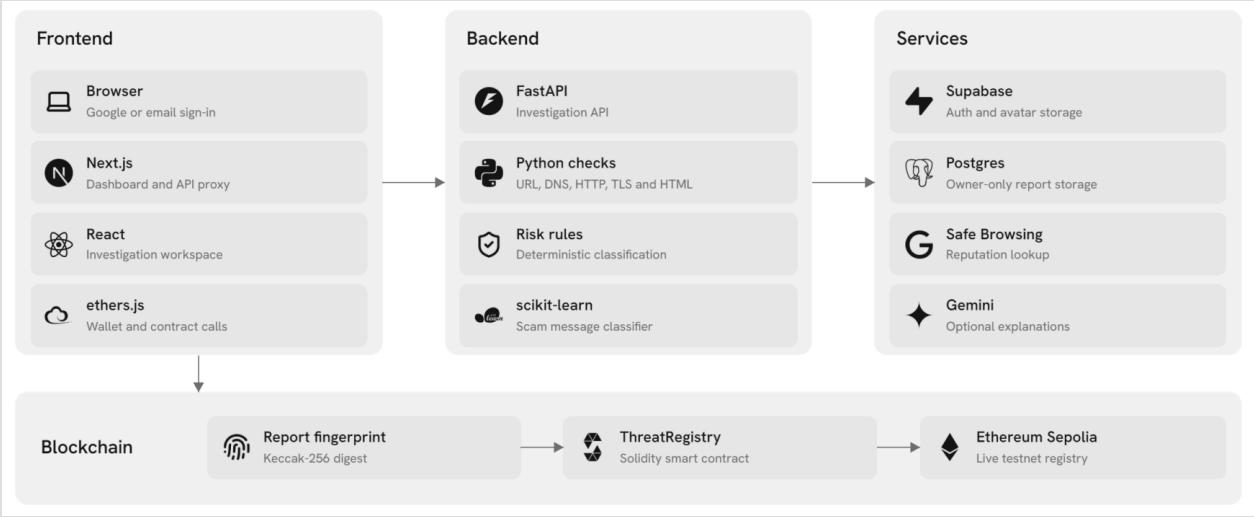
Capability	What it does	Status
URL investigation	Normalises the URL, analyses domain structure and look-alike or homoglyph patterns, follows redirects and inspects DNS, HTTP, security headers and static HTML.	Working
TLS and web trust	Verifies the certificate against the system trust store for the hostname and checks leaf key strength and signature hash.	Working

Capability	What it does	Status
Threat intelligence	Checks submitted URLs against Google Safe Browsing, with distinct error states when the provider is unavailable.	Working, needs API key
Email analysis	Inspects pasted emails, raw headers and .eml files for sender mismatches, authentication results, risky attachments, links and fraud language.	Working
Gmail inbox protection	Screens the latest emails in a connected inbox, raises an in-app alert for likely fraud, and adds flagged emails to Email analysis.	Working
Scam message analysis	Combines a trained classifier with explainable indicators and extracts URLs, phone numbers and email addresses without opening any link.	Working
Threat correlation	Connects saved investigations through exact shared domains and leaf certificate fingerprints. Shared indicators never change a verdict.	Working
AI explanations	Built-in rule-based explanations cite report evidence. Optional Gemini explanations are schema-validated.	Working
Report integrity ledger	Registers salted report fingerprints through MetaMask and verifies receipts independently.	Live on Sepolia
Dashboard	Overview, Scans, Messages, Certificates, Threats, Reports, Threat ledger and Settings, with Google and email sign-in.	Working



WebAssure dashboard, shown with sample scans.

4. Architecture



System architecture.

The browser signs in with Supabase Auth and calls the investigation API through a Next.js proxy. The FastAPI service verifies every bearer token with Supabase Auth, then sends that same user token to PostgREST. Gmail access runs through the same FastAPI service with verified sessions. Owner filters and Postgres row-level security both restrict access, and the server never holds a service-role key. Wallet and contract calls happen in the browser through ethers.js, so the application never receives a private key.

5. Investigation pipeline

A submitted URL passes through the following stages. Each stage records its own status, so the final report shows exactly what was and was not covered.

1. **Normalise and analyse offline:** URL structure, registrable domain, homoglyph and brand look-alike signals.
2. **Validate the destination:** resolve DNS and continue only if every address is public.
3. **Fetch safely, hop by hop:** connect to the validated address, verify TLS and re-validate each redirect, for at most six hops.
4. **Inspect the response:** security headers and bounded static HTML. Scripts, forms and linked resources are never executed.
5. **Check reputation:** query Google Safe Browsing for every URL in the chain.
6. **Classify and explain:** apply the deterministic rules below, then generate an explanation of the evidence.

Risk classification. The first matching rule decides the result. Classifications are not calibrated probabilities, and Low Risk never proves that a website is safe.

Classification	Rule
Confirmed Malicious	A threat intelligence provider returned a verified match with evidence.

Classification	Rule
High Risk	At least two independent signal groups have significant indicators, and at least one is strong.
Suspicious	At least one moderate or strong threat indicator was found.
Low Risk	No significant indicators, and all core checks completed.
Inconclusive	No significant indicators, but core coverage is incomplete.

6. AI layer

Message classifier. Messages are classified with TF-IDF features and Logistic Regression, trained on the 5,574-message UCI SMS Spam Collection with an 80/20 stratified split. Multinomial Naive Bayes was evaluated as a comparison and rejected because of its lower spam recall.

Model (1,115-message test split)	Accuracy	Precision	Recall	F1
Logistic Regression (selected)	98.39%	94.56%	93.29%	93.92%
Multinomial Naive Bayes	96.77%	100.00%	75.84%	86.26%

Precision, recall and F1 are for the spam class. These are results on one held-out split of a general SMS spam dataset, not measured real-world scam detection performance, so the classifier is shown alongside explainable indicators.

Generated explanations. Gemini is optional and runs after classification. Evidence is passed to it as untrusted data, URLs in descriptions are stripped, output must match a JSON schema, and it has no ability to change a classification. If Gemini is unavailable, the built-in rule-based explanation is used.

7. Email analysis and inbox protection

Email analysis. A user can paste an email, paste raw headers or upload an .eml file. The analyzer weighs sender mismatches, reported authentication results, attachment risk, link findings and fraud language into a 0 to 100 score and one of four results: Safe, Suspicious, Scam or Phishing. The score comes from deterministic weighted indicators and is not a calibrated probability.

Gmail inbox protection. Each signed-in user can connect their own Gmail account with read-only Google access.

1. **Connect:** a single-use state value binds the Google consent screen to the WebAssure user who started it, so a connection cannot be attached to someone else.
2. **Store:** Google tokens are encrypted before they are saved, and access is always resolved from the verified session, never from an email address in a request.
3. **Screen:** the 15 newest inbox emails are checked while the dashboard is open. Links are assessed from their text and are never opened, because a link may be a one-time login or an unsubscribe action.
4. **Warn:** likely phishing or scam emails raise a security alert across the dashboard. Each alert links to its report and to the message in Gmail.

5. **Keep in sync:** flagged emails join the private Email analysis history once, using a stable identifier. Full email bodies are not saved.

8. Blockchain integrity layer

A blockchain record can prove that a report has not changed and which wallet registered it. It cannot prove that the report is true, so WebAssure claims only integrity and provenance.

1. **Snapshot:** the saved report is frozen together with a random 32-byte nonce, which stops anyone guessing report contents from the public fingerprint.
2. **Fingerprint:** the snapshot is canonicalised and hashed with Keccak-256.
3. **Register:** the user approves a MetaMask transaction that sends only the digest to the `ThreatRegistry` Solidity contract.
4. **Verify:** verification recomputes the fingerprint and checks the transaction, contract address, registration event, registering address and contract state. It needs no login, application server or wallet signature.

Deployment	Value
Network	Ethereum Sepolia (chain ID 11155111)
Registry contract	`0x5AB0A5fE5026249aDFe1Fb7362C124cdA5296581`
Deployment transaction	`0x94f6a8da67b6f3dc0319b07bb603d0e268f0a61a18773bd84d3a7cf67bb63a10`
Stored on-chain	Fingerprint, reporter wallet and timestamp only
Kept off-chain	The report, its URLs and any personal data

9. Security and privacy

- **SSRF protection:** only globally routable addresses are allowed, connections go to the validated address, and every redirect is checked again.
- **Bounded inspection:** 5-second socket timeouts, a 256 KiB HTML limit, a six-hop redirect limit and four concurrent investigations. Compressed responses and attachments are not read.
- **No execution:** no scripts are run, no cookies are sent, and no exploit or intrusive test is attempted.
- **Private by default:** reports are owner-only through row-level security. Inaccessible report IDs return 404.
- **Inbox access:** every Gmail route requires a verified session, Google tokens are encrypted at rest, and disconnecting revokes the grant and deletes the tokens.
- **Prompt injection:** page content and messages are treated as untrusted and cannot influence a classification.
- **No sensitive collection:** WebAssure never asks for passwords, OTPs, private keys or seed phrases.

10. Challenges we solved

Challenge	How we solved it
A failed check must never look clean	Every check reports its own status and coverage. If core checks are incomplete and nothing significant was found, the result is Inconclusive, not Low Risk.
Inspecting hostile URLs safely	DNS validation, connecting only to the validated address, re-validation of each redirect, and strict limits on time, size and hops.
Keeping AI from overstating evidence	Classification is deterministic and happens first. AI receives evidence as untrusted data, must return schema-valid output, and cannot alter the verdict.
Separating suspicion from proof	Confirmed Malicious requires a verified provider match. High Risk requires corroboration from independent signal groups.
Publishing proof without leaking data	Only a nonce-salted Keccak-256 digest goes on-chain. Report contents remain in a private receipt held by the user.
Screening an inbox without side effects	Background screening inspects links offline. Opening them could consume a one-time login or trigger an unsubscribe.
Multi-user privacy without a privileged key	The API forwards each verified user token, so Postgres row-level security enforces ownership on every request.

11. Testing

The repository has **148 backend tests** and **27 frontend tests**, all passing at the time of writing. They cover URL analysis, the investigation pipeline, certificates, threat intelligence, explanations, message and email analysis, Gmail connection security, the authenticated proxy, correlation and the registry. Registry tests use a real in-memory EVM for deployment, registration, duplicate rejection and tamper detection. Network and provider tests are mocked, so they verify behaviour and do not measure real-world detection accuracy.

12. Limitations

- Certificate Transparency and revocation checks are not implemented yet, and each report states this.
- Automated checks cannot guarantee that a website is safe, and absence of known threats is not proof of safety.
- The registry is deployed on a testnet. Registration proves integrity and wallet provenance, not the truth of an assessment.
- Correlation uses exact shared evidence only and does not attribute reports to a campaign.
- Gmail read access is a restricted Google permission. Until Google verifies the app, only approved test users can connect, and Testing-mode connections expire after about seven days.
- Fraud alerts appear inside WebAssure, not inside Gmail itself, and only while the dashboard is open.

- The backend is a local MVP that runs as a single worker, and email data uses local storage.

13. What is next

- Certificate Transparency, revocation and scheduled certificate monitoring.
- Validated campaign attribution built on exact shared evidence.
- A contract audit before moving beyond the Sepolia testnet.
- Google verification for public Gmail access, and a browser extension that warns inside Gmail.
- Per-user rate limits, data retention controls, network egress restrictions and a durable job queue.

14. Disclosures

Open-source software: Next.js, React, Supabase client, ethers, jsPDF, html-to-image, Solidity compiler, Ganache, FastAPI, Uvicorn, tldextract, confusable-homoglyphs, idna, cryptography, scikit-learn and joblib. **Services and data:** Supabase, Google Safe Browsing, Google Gemini, the Gmail API and the UCI SMS Spam Collection. **AI tools:** Claude Code assisted with parts of the implementation and documentation, and Google Gemini is part of the product as the optional explanation provider.

Source code: github.com/pradhan-not-found/Hackmatrix-26-